Reading: Course 5 resources and citations

Module 1: Introduction to asset security

Resources

The emergence of cloud security

- The U.K.'s National Cyber Security Centre
- The Cloud Security Alliance®
- CompTIA Cloud+

Security guidelines in action

- You can learn more about implementing the CSF in this report by CISA that outlines how the framework was applied in the commercial facilities sector.

Citations

The what, the why, and how of asset security

- National Institute of Standards and Technology. (n.d.). *Glossary*. Accessed December 2022.

Understand threats, risks, and vulnerabilities

- Cynet. (n.d.). *What is incident response?*
- Kidd, C. (2022, September 20). *Security 101: Vulnerabilities, threats & risk explained*. Splunk.
- Sectigo. (2020, October 26). *What is the difference between a threat, a vulnerability, and a risk?*

Security starts with asset classification

- National Cyber Security Centre. (n.d.). *Asset management for cyber security*.

Common classifications requirements

- Center for Disease Control and Prevention. (n.d.). *Health insurance portability and accountability act of 1996 (HIPAA)*. Public Health Law.
- Educause. (n.d.). *Asset and data management*.
- General Data Protection Regulation. (n.d.). *What is GDPR, the EU's new data protection law?*
- Official PCI security standards council site. (n.d.). *PCI Security Standards Council*.
- Sotnikov, I. (2020, September 2). *Data classification: what it is and how to implement it*. Netwrix.
- U.S. Department of Education Student Privacy Policy Office. (n.d.). *What is FERPA?*

Assets in a digital world

- Professor Messer. (n.d.). *States of data — CompTIA Security+ SY0-501 — 601*.

The emergence of cloud security

- Burning Glass. (2020, October). *Protecting the future: The fastest-growing cybersecurity skills*.
- Cloud Security Alliance. (n.d.). *Conquer Cloud Security*. Cloud Security Alliance.
- CompTIA. (n.d.). *CompTIA Cloud+*.
- Moore, S. (2021). *Gartner forecasts worldwide security and risk management spending to exceed $150 billion in 2021*. Gartner.
- National Cyber Security Centre. (2022, May 10). *Cloud security shared responsibility model - NCSC.GOV.UK*. National Cyber Security Centre.
- National Cyber Security Centre. (n.d.). *Introduction to cloud security*. Page 2.
- Ranger, S. (2022). *Cloud computing means big opportunities—And big threats*. ZDNET.
- McAfee. (n.d.). *What is cloud security? How to secure the cloud*.
- Microsoft. (n.d.). *Trend report: Why businesses are moving to the cloud*. The Small Business Cloud Outlook.
- Salesforce. *(n.d.)*. *What is PaaS—Platform as a service?*
- Sky High Security. (n.d.). *What is cloud security? How to secure the cloud*.

Elements of a security plan

- Info Security Institute. (2019, June 28). *CISSP prep: Security policies, standards, procedures, and guidelines*.

The NIST Cybersecurity Framework

- National Institute of Standards and Technology. (n.d.). *An introduction to the components of the framework*. Accessed December 2022.
- National Institute of Standards and Technology. (n.d.). *History and creation of the framework*. Accessed December 2022.

Module 2: Protect organizational assets

Resources

Symmetric and asymmetric encryption

- Heartbleed bug
- Kerchoff's principle

Identity and access management

- IDPro

Citations

Information privacy: Regulations and compliance

- Andruss, R. (n.d.). *A brief history of data privacy and what lies ahead*. Skyflow
- Nast, C. (n.d.). *What is GDPR? The summary guide to GDPR compliance in the UK*. Wired UK.
- Rossow, A. (n.d.). *The birth of GDPR: What is it and what you need to know*. Forbes.
- Sirota, D. (2017). *GDPR – What security pros need to know about the new era of privacy regulations*. CSO Online.

- GDPR. (2018). *What is GDPR, the EU's new data protection law?*
- GDPR. (2018). *Art. 5 GDPR - Principles relating to processing of personal data*.

Activity: Determine appropriate data handling practices

- National Institute of Standards and Technology. (2018, April 16).*Framework for Improving Critical Infrastructure Cybersecurity*. Version 1.1. Accessed 2023.
- National Institute of Standards and Technology. (2020, September). *Security and Privacy Controls for Information Systems and Organizations*. Revision 5. Accessed 2023.
- National Institute of Standards and Technology. (2019, May 20). *Cybersecurity Framework Manufacturing Profile*. NISTIR 8183. Accessed 2023.

Fundamentals of cryptography

- IBM. (2022, November 30). *Cryptography*.
- Geeks for Geeks. (2022, September 25). *Caesar cipher in cryptography*.

Public key infrastructure

- Fruhlinger, J. (2020, May 29). *What is PKI? And how it secures just about everything online*. CSO.

Symmetric and asymmetric encryption

- IBM. (n.d.). *What is encryption? Data encryption defined*. Protecting your data.
- Cisco. (n.d.). *What is encryption? Explanation and types*. Security.
- National Institute of Standards and Technology. (n.d.). *Fips pub 140-3*. Computer Security Resource Center. Accessed December 2022.
- GDPR. (2018, November 7). *What is GDPR, the EU's new data protection law?* Getting started.
- Cobb, M., Loshin. P. (2021, August). *Data Encryption Standard (DES)*. Tech Target. Data security and privacy.
- Garfinkel, S. (2022, February 23). MIT Technology Review. *5 MIT patents that changed computing*. MIT News.
- Scott, B. (2020, August 12). NordPass. *Military-grade encryption explained*. Online Security ABC.

Non-repudiation and hashing

- Awati, R. (n.d.). *What is nonrepudiation?* Tech Target.

The evolution of hash functions

- Arias, D. (2021, February 5). Auth0. *Adding salt to hashing: A better way to store passwords*.
- Constantin, L. (2021, January 13). CSO. *What is hashing: How this cryptographic process protects passwords*. Encryption.
- Handschuh, H. (2005). Springer US. *SHA family (Secure Hash Algorithm)*.
- Okta. (n.d.). *Hashing algorithm overview: Types, methodologies & usage*. Identity-101.
- Sagar, F. A. (2016, September). Indiana State University. *Cryptographic Hashing Functions-MD5*.
- Schacklett, M. E. (2021, August). Tech Target. *MD5*. Network Security.

- Indiana University. (2018, January, 18). *What are bits, bytes, and other units of measure for digital information?* Knowledge Base.

Access controls and authentication systems

- Identity Management Institute. (n.d.). *AAA identity and access management framework model*.

The mechanisms of authorization

- IBM. (2021, March 3). *HTTP basic authentication*.

Improve authentication and authorization for a small business

- Bhargava, R. (2019). *Why aren't startups using Active Directory?* JumpCloud.
- IBM. (2021, 3 3). *IBM Spectrum project. Examples: event logs*.

Module 3: Vulnerabilities in systems

Resources

The OWASP Top 10

- OWASP's Top 10

Open source intelligence

- VirusTotal
- MITRE ATT&CK®
- OSINT Framework
- Have I been Pwned

The importance of updates

- CISA recommends discontinuing the use of EOL software

Penetration testing

- HackerOne

Portfolio Activity: Analyze a vulnerable system for a small business

- NIST SP 800-30 Rev. 1

Approach cybersecurity with an attacker mindset

- NISTs National Vulnerability Database (NVD)

Activity: Identify the attack vectors of a USB drive

- security tips on using caution with USB drives

Citations

Vulnerability management

- Cybersecurity & Infrastructure Security Agency. (n.d.). *Overview of cyber vulnerabilities*.
- Cybersecurity & Infrastructure Security Agency. (n.d.). *Cyber threats and advisories.*

- McGuiness, T. 2021. *Defense in depth*. Version 1.2E.

Defense in depth strategy

- McGuiness, T. 2021. *Defense in depth*. Version 1.2E.

Common vulnerabilities and exposures

- Armending, T. (2017, July 10). *What is CVE, its definition, and purpose?*
- CVE. (n.d.). *About the CVE program*.
- National Institute of Standards and Technology. (n.d.). *National vulnerability database*. Information technology laboratory. Accessed December 2022.

The OWASP Top 10

- SolarWinds cyber attack (2020)
- Canales, I. J., Katie. (n.d.). *The US is readying sanctions against Russia over the SolarWinds cyber attack. Here's a simple explanation of how the massive hack happened and why it's such a big deal*. Business Insider.
- Khan, S., Kabanov, I., Hua, Y., & Madnick, S. (2022). *A systematic analysis of the capital one data breach: Critical lessons learned. ACM Transactions on Privacy and Security, 26(1), 1-29.*
- Open Web Application Security Project. (n.d.). *A02: 2021 cryptographic failures*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A01: 2021 broken access control*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). A03: 2021 injection. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A04: 2021 insecure design*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A05: 2021 security misconfiguration*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A06: 2021 vulnerable and outdated components*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A07: 2021 identification and authentication failures*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A08: 2021 software and data integrity failures*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A09: 2021 security logging and monitoring failures*. OWASP Top 10: 2021. Accessed December 2022.
- Open Web Application Security Project. (n.d.). *A10: 2021 server side request forgery*. OWASP Top 10: 2021. Accessed December 2022.
- Owasp Foundation. (n.d.) The open source foundation for application security.
- Open Web Application Security Project. (n.d.). *OWASP Foundation*. OWASP Top 10: 2021. Accessed December 2022.
- Sharma, A. (2021, October 20). *SSRF attacks explained and how to defend against them*. CSO Online.

- Synopsys. (n.d.). *What is the OWASP top 10 2021 and how does it work?*

Open source intelligence

- CrowdStrike. (2022, February 25). *What is OSINT Open Source Intelligence?* Cybersecurity 101.
- Hunt, T. (n.d.). *Have I Been Pwned*. Who, what & why.
- Nordine, J. (n.d.). *OSINT Framework*.
- Nurudini, A. (n.d.). *Offensive Open Source Intelligence*. OWASP.
- Tabatabaei, F., & Wells, D. (2016, January). *OSINT in the Context of Cyber-Security*. Open source intelligence investigation, pp. 213-231.

Vulnerability assessments

- Imperva. (n.d.). *Vulnerability assessment*.

Approaches to vulnerability scanning

- Aher, R. (2018, October 30). *A complete guide on vulnerability scanning—Types, importance, procedures, and measures*.
- Balbix. (2019, November 27). *Vulnerability scanners and scanning tools: What to know*. Insights.
- Rapid7. (n.d.). *Discovery Scan*. Metasploit documentation.
- Snyk. (n.d.). *Vulnerability Scanner: What is it and how does it work?* Security Fundamentals.

The importance of updates

- Cybersecurity and Infrastructure Security Agency. (2023, February 23). *Understanding Patches and Software Updates*. CISA Tips.
- Kaspersky. (n.d.). *What is WannaCry ransomware?* Threats.
- Microsoft. (2022, October, 4). *Manually deploy software updates*. Software update management.
- National Cyber Security Centre. (n.d.). *Keeping devices and software up to date*. Device Security Guidance. Accessed December 2022.
- Symanovich, S. (2021, January 23). *5 reasons why general software updates and patches are important*. Security center.
- Smith, F. (2018, June 12). University of Maryland, Baltimore. *The Importance of General Software Updates and Patches*. The Elm Archive.
- Tkacik, D. (2020, March 16). Carnegie Mellon University. *Why people delay software updates, despite the risks*. CyLab.
- Vailshery, L. S. (2022, November 22). Statista. *Number of Internet of Things (IoT) connected devices worldwide from 2019 to 2021, with forecasts from 2022 to 2030*. Technology & Telecommunications.

Portfolio Activity: Analyze a vulnerable system for a small business

- National Institute of Standards and Technology. (n.d.). *SP 800-30 Rev. 1*.

Protect all entry points

- Infosec Institute. (2012, February 17). Attack surface reduction - Chapter 4.

Approach cybersecurity with an attacker mindset

- Firch, J. (2021, September 7). PurpleSec. *Red Team VS Blue Team: What's The Difference?* Cyber Security.
- LeTellier, V. (2019, September 1). Security Management. *How to Use the Attacker Mentality for Good*. Risk Management.
- Wong, E. Y., Hutton, K. R., Gagnon, R. F. (2018, July). *Thinking Outside-the-Box for Cyber Defense: Introducing an Innovation Framework for the 21st Century*. ResearchGate. Cyber Conflict.

Types of threat actors

- Cybersecurity & Infrastructure Security Agency. (n.d.). *Defining insider threats*.
- Grimes, R. A. (2019, February 7). *What is an advanced persistent threat (Apt)? 5 signs you've been hit*. CSO Online.
- Imperva. (n.d.). *Cyber security threats | types & sources*.
- Kaspersky. (n.d.). *Black hat, white hat, and gray hat hackers – Definition and explanation*.
- Professor Messer. (n.d.). *Attack vectors - SY0-601 CompTIA Security+: 1.5*.
- NordVPN. (2022, August 2). *What are nation-state actors?*

Pathways through defenses

- Shacklett, M.E. (2021, April). *Attack vector*.
- Tunggal, A.T. (2023, January 08). *What is an attack vector? 16 common attack vectors in 2023*.

Fortify against brute force cyber attacks

- Crowdstrike. (2022, May 18). *Pass-the-hash-attack*. Cybersecurity 101.
- Fortinet. (n.d.). *What is Brute Force Attack? | Definition, Types & How It Works*. Cyber Glossary.
- G Suite. (n.d.). *What is CAPTCHA?* Admin Help.
- Lee, B. (2022). *NIST 800-63b Password Guidelines and Best Practices*. Specops Software.
- Kaspersky. (n.d.). *Brute force attack: Definition and examples*. Home Security.
- National Kaohsiung Normal University. (n.d.). *What is exhaustive key search?* RSA Labs.
- Shankdhar, P. (2020, September 24). *Popular Tools for Brute-force Attacks*. Infosec Resources.

Module 4: Threats to asset security

Resources

Social engineering tactics

- *Twitter Hack of 2020*
- OUCH!
- Scamwatch

Types of phishing

- Google's phishing quiz
- Phishing.org
- Anti-Phishing Working Group (APWG)

An introduction to malware

- WannaCry
- INFOSEC's introductory course on malware analysis

Prevent injection attacks

- OWASP's SQL injection detection techniques

Traits of an effective threat model

- CVE-2021-44228

Activity: Apply the PASTA threat model framework

- *CVE® list*
- *OWASP*

Citations

The criminal art of persuasion

- Kaspersky. (n.d.). *What social engineering?* Resource center.
- Ragan, S. (2021, June 2). *What are phishing kits? Web components of phishing attacks explained*. Security.

Social engineering tactics

- Allen, J., & Firch, J. (2022, July 7). PurpleSec. *Social Engineering: What Is It And Why Is It Effective?* Cyber Security Maturity Model.
- Cybersecurity and Infrastructure Security Agency. (2020, October 22). *Avoiding Social Engineering and Phishing Attacks*. National Cyber Awareness System.
- IT Governance. (n.d.). *What is Social Engineering? | Techniques & Prevention*. Cyber security solutions.
- Kaspersky. (2020, March 31). *Holy Water: a creative water-holing attack discovered in the wild*. Corporate news.
- Kaspersky. (n.d.). *Ways to avoid social engineering attacks*. Home security.

Phishing for information

- Fruhlinger, J. (2022, April 12). *What is phishing? Examples, types, and techniques*.
- National institute of standards and technology. (2022, April). *Guide to enterprise patch management planning: Preventative maintenance for technology*. SP 800-40 Rev. 4. Accessed December 2022.

Types of phishing

- Anti-Phishing Working Group. (n.d.). APWG.org.
- Dimov, I. (2013, March 1). *Phishing techniques: Similarities, differences and trends – Part I: (mass phishing)*. Infosec.
- Google. (n.d.). Google's phishing quiz.
- KnowBe4. (n.d.). *Phishing*.

- Phishing.org (n.d.). Phishing.org
- Verizon Enterprise. (n.d.). *The history of phishing attacks*.

Malicious software

- Malware Bytes. (n.d.). *Malware*.

An introduction to malware

- MalwareBytes. (n.d.). *Adware*.
- Cybersecurity & Infrastructure Security Agency. (2022, February 10). *2021 Trends show increased globalized threat of ransomware*. Accessed 2022.
- Imperva. (n.d.). *What is a rootkit?*
- Infosec Institute. (n.d.). *Malware analysis introduction*. Courses.
- Kaspersky. (2021). *What is scareware? Definition and explanation*.
- The University of Manchester. (2023, January 27). *History of Malware*.
- Microsoft. (2022, April 8). *Virus alert about Blaster worm and its variants – Windows Server*. Microsoft Learn.
- Microsoft 365. (2022, December 14). *How trojans work*. Learn.
- McAfee. (n.d.). *What is malware and why do cybercriminals use malware?*
- Norton. (n.d.). *10 types of malware + how to prevent malware from the start*.
- Trojan malware (n.d.). *Microsoft Learn*. Security Intelligence.

The rise of cryptojacking

- Gillis, A.S. (n.d.). *Bitcoin mining*. Threat management.
- Interpol. (n.d.). *Cryptojacking*.

Cross-site scripting

- Open Web Application Security Project. (n.d.). *Cross site scripting (XSS)*.
- Portswigger. (n.d.). *Cross-site scripting*.

Exploitable gaps in databases

- Open Web Application Security Project. (n.d.). *SQL Injection*.
- W3Schools. (n.d.). *SQL injection*.

A proactive approach to security

- Open Web Application Security Project. (n.d.). *Threat modeling process*.
- Gitlab. (n.d.). *Threat modeling*.

PASTA: The Process for Attack Simulation and Threat Analysis

- UcedaVelez, T. (2021, November 23). *What is PASTA threat modeling? Step into the kitchen as the co-founder of PASTA threat modeling breaks down the 7 steps*.

Traits of an effective threat model

- Amazon AWS. (n.d.). *What is DevSecOps?* Developer Security Operations.

- Microsoft. (2022, August 25). *Microsoft Threat Modeling Tool threats*. Microsoft Learn. Azure.
- Cybersecurity and Infrastructure Security Agency. (2021, December 23). *Mitigating Log4Shell and Other Log4j-Related Vulnerabilities*. National Cyber Awareness System. Accessed December 2022.
- National Institute of Standards and Technology. (2022, December 9). *CVE-2021-44228 Detail*. National Vulnerability Database. Accessed December 2022.
- Octotrike. (n.d.). *What does Trike do?* Trike FAQ.
- Sangalli, A., & Lewis, K. (2020, November 16). *Global State of Mobile*. ComScore.
- Sengupta, S. (2021, November 15). *Why Is Application Security Important for Business*. Crash Test Security. Business Guide.
- Shostack+Associates. (n.d.). *The Ultimate Beginner's Guide to Threat Modeling*. Resources.
- Synopsys. (2017, May 26). *When should threat modeling take place in the SDLC?* Application security.
- ThreatModeler. (2018, October 9). *Threat Modeling Methodologies: What is VAST?*
- VerSprite. (2021). *PASTA Threat Modeling - Breaking Down All 7 Steps*. What is PASTA threat modeling.

Apply the PASTA threat model framework

- Shevchenko, N. , (2018, December 3). *Threat Modeling: 12 Available Methods*. Carnegie Mellon University.
- UcedaVelez, T. (2021, November 23). *PASTA Threat Modeling - Breaking Down All 7 Steps*. VerSprite.
- UcedaVelez, T. (2012). *Real World Threat Modeling Using the PASTA Methodology*. VerSprite.
